



Introducción al Marco Legal y Auditorías de Ciberseguridad



Con la colaboración:



Auditorías de ciberseguridad en entornos IT/OT

Módulo 9



Auditorías de ciberseguridad en entornos IT/OT

Introducción a las auditorías de ciberseguridad

- Una auditoría de ciberseguridad evalúa el cumplimiento de normas, políticas y medidas técnicas para proteger sistemas y datos.
- En OT, su objetivo no es solo proteger información, sino también **garantizar la continuidad operativa y la seguridad física**.
- Son clave para identificar riesgos antes de que ocurran incidentes reales.

Tipos de auditoría:

- **Interna / Externa**
- **De cumplimiento** (ISO 27001, IEC 62443, NIS2, ENS)
- **Técnica** (redes, SCADA, accesos)
- **De madurez o regulatoria**

Diferencias frente a IT:

- En OT prima la **disponibilidad**, la seguridad humana y la estabilidad operativa.
- Deben planificarse cuidadosamente para **no interrumpir procesos industriales**.

Las auditorías deben verse como una **herramienta de mejora continua**, no como un control punitivo.

Auditorías de ciberseguridad en entornos IT/OT

Marco legal y normativo aplicable

- Las auditorías de ciberseguridad en OT están impulsadas por **obligaciones legales, normativas sectoriales y estándares internacionales**.

Normas clave aplicables:

- **ISO/IEC 27001**: exige auditoría interna periódica del SGSI.
- **IEC 62443-2-4**: establece requisitos de ciberseguridad para proveedores e integradores OT.
- **ENS (España)**: obliga a auditorías bienales de seguridad en el sector público.
- **NIS2**: exige controles periódicos de gestión de riesgos y supervisión para entidades esenciales e importantes.
- **CER Directive (UE)**: obliga a evaluaciones y auditorías de resiliencia en sectores críticos.
- **DORA (sector financiero)**: impone auditorías de resiliencia operativa digital.
- **TISAX (automoción)**: modelo de auditoría reconocido para proteger la información sensible del sector.

Auditorías de ciberseguridad en entornos IT/OT

Marco legal y normativo aplicable

Las auditorías permiten demostrar cumplimiento ante:

- Autoridades nacionales (AEPD, INCIBE, CNPIC, CCN)
- Certificadoras externas
- Clientes o socios comerciales (requisito contractual)
- Las organizaciones OT deben identificar qué regulaciones les aplican y planificar auditorías específicas o integradas según su sector.

Auditorías de ciberseguridad en entornos IT/OT

Objetivos de una auditoría

- Evaluar el **cumplimiento normativo** en materia de ciberseguridad (ISO, IEC, NIS2, ENS, LPIC...).
- Verificar si los **controles técnicos y organizativos** aplicados protegen adecuadamente los sistemas OT.
- Identificar **brechas de seguridad** antes de que sean explotadas (vulnerabilidades, accesos indebidos, fallos en red, etc.).
- Analizar la **gestión de riesgos** y comprobar si se ha realizado un análisis adecuado del impacto en la operación.
- Revisar los **planes de continuidad y recuperación** ante incidentes que puedan afectar procesos industriales.
- Comprobar la **concienciación del personal** técnico y de planta sobre ciberseguridad.

Auditorías de ciberseguridad en entornos IT/OT

Objetivos de una auditoría

- Evaluar el grado de **coordinación entre IT y OT**, y si hay una gobernanza clara en ciberseguridad industrial.
- Validar el ciclo completo de gestión de incidentes: detección, respuesta, notificación y lecciones aprendidas.
- Confirmar si los **proveedores críticos** cumplen con medidas adecuadas (cadenas de suministro seguras).
- Recoger evidencia para mostrar **diligencia debida** ante clientes, autoridades o aseguradoras.

Auditorías de ciberseguridad en entornos IT/OT

Metodología y Herramientas

Las auditorías en OT deben seguir un enfoque sistemático y documentado, adaptado a entornos industriales.

Se pueden aplicar **métodos estándar** de auditoría como:

- **ISO 19011 – Directrices para auditorías de sistemas de gestión**
- Estructura el proceso en fases: planificación, ejecución, informe y seguimiento.
- Aplica tanto a auditorías internas como externas (por certificadoras).
- En OT, exige especial cuidado en la **planificación para evitar interrupciones**.

Auditorías de ciberseguridad en entornos IT/OT

Técnicas específicas en ciberseguridad OT

Técnica	Descripción
Checklist / Cuestionario	Basado en ISO 27001, IEC 62443, NIS2, etc. Adaptado al entorno OT.
Entrevistas	A responsables de planta, técnicos de mantenimiento, CISO, IT y OT.
Inspección técnica	Verificación en campo: segmentación de red, acceso físico, SCADA, firewalls industriales.
Revisión documental	Políticas, procedimientos, análisis de riesgos, bitácoras, evidencias de formación y registros.
Observación directa	Evaluación de hábitos reales: cómo se accede a un armario de control, cambios en PLC, etc.
Simulación / test de respuesta	Evaluar reacciones ante incidentes simulados (brechas, paradas, sabotajes).

Auditorías de ciberseguridad en entornos IT/OT

Herramientas útiles:

- **Herramientas que analizan el tráfico de la red** proporcionando visibilidad de los elementos de esta con informes de cumplimiento.
- **Herramientas que escanean la red**, para análisis de vulnerabilidades, si se permite (usar con mucha precaución)
- **Hojas de cálculo / Herramienta de Gestión de Riesgo**: para llevar el seguimiento de hallazgos y planes de acción.

Consideraciones clave en OT:

- Evitar escaneos agresivos o intrusivos que puedan afectar equipos industriales.
- Incluir siempre a los **responsables de producción y mantenimiento** en la planificación.
- Garantizar que las auditorías respeten los **procesos operativos críticos** y los períodos de parada.

Auditorías de ciberseguridad en entornos IT/OT

Roles involucrados en una auditoría de ciberseguridad OT

La auditoría en entornos OT implica una amplia coordinación entre perfiles técnicos, de gestión y operacionales. Cada rol tiene responsabilidades clave para asegurar el éxito del proceso.

Auditor líder (interno o externo)

- Planifica, coordina y ejecuta la auditoría.
- Evalúa cumplimiento y redacta el informe final.
- En OT, debe tener conocimientos técnicos del entorno industrial.

CISO / Responsable de ciberseguridad

- Garantiza la colaboración interna con el equipo auditor.
- Aporta documentación, procedimientos y evidencias.
- Coordina los planes de acción tras la auditoría.

Auditorías de ciberseguridad en entornos IT/OT

Roles involucrados en una auditoría de ciberseguridad OT

Responsable OT / Ingeniero de planta

- Actúa como interlocutor principal en campo.
- Aporta conocimiento del entorno productivo, SCADA, PLCs, etc.
- Supervisa las inspecciones y validaciones técnicas sin afectar la operación.

Responsable IT / Infraestructuras

- Aporta evidencias relacionadas con redes, accesos, backups y segmentación.
- Apoya en los aspectos técnicos del entorno híbrido IT/OT.

Dirección / Alta gerencia

- Define el alcance estratégico de la auditoría.
- Recibe el informe final y valida los planes de mejora.
- Es clave para dar legitimidad y recursos al proceso.

Auditorías de ciberseguridad en entornos IT/OT

Roles involucrados en una auditoría de ciberseguridad OT

DPO (si hay tratamiento de datos personales)

- Evalúa cumplimiento del RGPD si hay datos personales en sistemas OT (videovigilancia, accesos, trazabilidad de operarios).

Proveedores o integradores OT

- Pueden ser auditados si tienen acceso o responsabilidades en sistemas industriales.
- Aportan información sobre mantenimientos, actualizaciones y seguridad del software OT.
- En auditorías externas (por organismos o certificadoras), también puede intervenir:

Entidad de certificación (acreditada ISO/IEC)

Autoridad reguladora (ej. INCIBE, CNPIC, AEPD, autoridad NIS2)

Auditorías de ciberseguridad en entornos IT/OT

Preparación de una auditoría

Una preparación adecuada es clave para asegurar que la auditoría sea eficaz, relevante y no disruptiva para la operación industrial.

Definir el alcance

- ¿Qué sistemas, áreas o instalaciones serán auditadas?
- Incluir redes OT, sistemas SCADA, ICS, y elementos compartidos con IT.
- Considerar también terceros (proveedores con acceso remoto, software industrial, etc.).

Revisión documental previa

- Políticas de seguridad, análisis de riesgos, planes de contingencia, inventario de activos, procedimientos operativos.
- Verificar si existen registros de auditorías anteriores y seguimiento de acciones correctoras.

Elaboración del plan de auditoría

- Fijar fechas, horarios y responsables por área.
- Coordinar con producción para evitar interferencias.
- Indicar si se harán visitas físicas, entrevistas, revisión remota o pruebas técnicas.

Auditorías de ciberseguridad en entornos IT/OT

Preparación de una auditoría

Notificación a las partes implicadas

- Informar a personal de planta, IT, OT, legal y dirección.
- Designar interlocutores por área.
- Aclarar objetivos, método y confidencialidad del proceso.

Preparación de herramientas y checklists

- Adaptar listas de verificación a normativas aplicables (ISO, IEC 62443, NIS2...).
- Incluir aspectos técnicos (segmentación, backups, accesos) y organizativos (formación, gobernanza, incidentes).

Consideraciones especiales en OT

- Programar inspecciones en momentos de baja carga operativa.
- Evitar cualquier acción que pueda interrumpir procesos críticos.
- Validar con mantenimiento cualquier revisión de dispositivos físicos o conexiones.

Auditorías de ciberseguridad en entornos IT/OT

Ejecución y análisis de la auditoría OT

Una vez planificada, la auditoría se desarrolla sobre el terreno, combinando observación directa, análisis técnico y revisión documental. En entornos OT, se requiere precisión y mínimo impacto operativo.

Inicio de la auditoría

- Reunión de apertura: repaso de objetivos, alcance y metodología.
- Verificación de permisos, accesos y medidas de seguridad para auditores.

Actividades típicas en campo:

- **Inspección de sistemas industriales:** SCADA, PLCs, redes, servidores OT, firewalls industriales.
- **Verificación física:** accesos a salas, armarios eléctricos, dispositivos portátiles.
- **Entrevistas:** personal de operaciones, mantenimiento, IT y responsables de seguridad.

Revisión documental en sitio

- Manuales, bitácoras de acceso, registros de mantenimiento, evidencias de formación.
- Comparación con lo declarado en políticas o el SGSI.

Auditorías de ciberseguridad en entornos IT/OT

Ejecución y análisis de la auditoría OT

Observaciones técnicas (con precaución)

- Análisis de topología y segmentación de red OT.
- Revisión de reglas de firewall y detección de activos no autorizados.
- Validación de backups, logs y control de cambios.

Registro y análisis de hallazgos

- Clasificación de desviaciones: leves, graves, no conformidades.
- Detección de buenas prácticas destacables.
- Análisis de causa raíz si se detectan vulnerabilidades críticas.
- **Reunión de cierre**
- Resumen preliminar de hallazgos.
- Aclaración de dudas antes del informe final.
- Posibilidad de acordar acciones preventivas urgentes.

Auditorías de ciberseguridad en entornos IT/OT

Informe de auditoría OT

El informe es el **resultado formal del proceso** de auditoría. Debe ser claro, útil y orientado a la mejora continua, especialmente en entornos OT donde las implicaciones pueden ser operativas y regulatorias.

Estructura típica del informe

- **Introducción:** objetivo, alcance, fechas, metodología y equipo auditor.
- **Resumen ejecutivo:** principales hallazgos, nivel de cumplimiento general y riesgos relevantes.
- **Hallazgos detallados:** evidencias, desviaciones, buenas prácticas y observaciones.
- **Clasificación de riesgos:** alto, medio, bajo (según impacto y probabilidad).
- **Plan de acciones correctivas:** con responsables y plazos.
- **Conclusiones y recomendaciones.**

Auditorías de ciberseguridad en entornos IT/OT

Informe de auditoría OT

Buenas prácticas en el informe

- Redactar con lenguaje comprensible para perfiles técnicos y no técnicos.
- Priorizar hallazgos que afectan la **disponibilidad, integridad y seguridad física de los sistemas OT**.
- Documentar claramente las **evidencias** recopiladas (fotos, registros, logs, entrevistas).

Valor añadido del informe

- Sirve como **documentación de cumplimiento legal** (ENS, NIS2, etc.).
- Apoya decisiones estratégicas de inversión en ciberseguridad.
- Refuerza la **rendición de cuentas** ante alta dirección, clientes o autoridades.

Auditorías de ciberseguridad en entornos IT/OT

Casos reales y prácticas comunes en auditorías OT

Las auditorías OT muestran patrones recurrentes, tanto en debilidades como en buenas prácticas. Analizar estos casos ayuda a preparar mejor a los equipos y evitar errores críticos.

Ejemplos de hallazgos frecuentes en auditorías OT

- ✗ Ausencia de un inventario actualizado de activos industriales.
- ✗ Contraseñas por defecto o compartidas en HMI o PLCs.
- ✗ Falta de segmentación clara entre red IT y red OT.
- ✗ Parches de seguridad obsoletos o imposibilidad de aplicarlos.
- ✗ Backups no testeados o almacenados en la misma red.
- ✗ Accesos remotos sin autenticación fuerte ni registro.
- ✗ No existencia de procedimiento de respuesta ante incidentes en entornos industriales.

Auditorías de ciberseguridad en entornos IT/OT

Casos reales y prácticas comunes en auditorías OT



Buenas prácticas observadas

- ✓ Etiquetado físico y lógico de equipos industriales.
- ✓ Accesos OT con doble factor en pasarelas remotas.
- ✓ Integración del CISO con los jefes de planta.
- ✓ Formación continua del personal de mantenimiento.
- ✓ Segmentación OT en zonas funcionales (modelo 62443).
- ✓ Procedimientos documentados para cambios en controladores.

Consejos prácticos para la preparación

- Simular auditorías internas antes de la visita oficial.
- Tener toda la documentación centralizada y actualizada.
- Preparar respuestas para justificar decisiones operativas heredadas.
- Promover una cultura de colaboración, no de ocultación.

Auditorías de ciberseguridad en entornos IT/OT

Auditoría vs evaluación de riesgos vs test de intrusión

¿Qué son, en qué se diferencian y cómo se complementan?

Estos tres conceptos son fundamentales en ciberseguridad, pero a menudo se confunden o se usan indistintamente. Aunque están relacionados, **tienen objetivos, enfoques y metodologías diferentes**, y todos son necesarios para una protección efectiva.

1. Auditoría de ciberseguridad

- **Definición:** Revisión sistemática y documentada del cumplimiento de políticas, normas o requisitos legales de seguridad (ej. ISO 27001, IEC 62443, ENS, NIS2).
 - **Objetivo:** Verificar si la organización aplica los controles establecidos y si lo hace correctamente.
 - **Enfoque:** Formal, estructurado y orientado al cumplimiento normativo.
 - **Método:** Revisiones documentales, entrevistas, inspecciones, análisis de evidencias.
 - **Periodicidad:** Programada (anual, bienal...) o por requerimiento externo.
 - **Resultado:** Informe con hallazgos, no conformidades, observaciones y recomendaciones.
- ✓ **Ejemplo:** Una auditoría de ciberseguridad OT detecta que no se ha realizado un test de restauración de backups críticos desde hace más de un año.

Auditorías de ciberseguridad en entornos IT/OT

Auditoría vs evaluación de riesgos vs test de intrusión

2. Evaluación de riesgos (risk assessment)

- **Definición:** Proceso para identificar, analizar y evaluar los riesgos que amenazan los activos de una organización.
 - **Objetivo:** Determinar el nivel de exposición a amenazas y priorizar medidas de mitigación.
 - **Enfoque:** Preventivo, estratégico, basado en impacto y probabilidad.
 - **Método:** Identificación de activos, amenazas, vulnerabilidades, impactos, cálculo de riesgos.
 - **Periodicidad:** Recurrente (al menos anual) y siempre que haya cambios relevantes.
 - **Resultado:** Mapa de riesgos, plan de tratamiento, y priorización de acciones.
- ✓ **Ejemplo:** El análisis de riesgos identifica que una línea de producción carece de redundancia eléctrica y eso pone en riesgo la disponibilidad de los sistemas de control.

Auditorías de ciberseguridad en entornos IT/OT

Auditoría vs evaluación de riesgos vs test de intrusión

3. Test de intrusión (penetration test / pentest)

- **Definición:** Simulación controlada de un ataque real para evaluar el nivel de exposición de sistemas ante intrusos.
 - **Objetivo:** Descubrir vulnerabilidades explotables y evaluar la eficacia de los controles técnicos.
 - **Enfoque:** Técnico, ofensivo, táctico y orientado a la detección de fallos concretos.
 - **Método:** Escaneos, explotación de vulnerabilidades, pruebas manuales o automáticas.
 - **Periodicidad:** Según cambios tecnológicos, despliegues nuevos o cumplimiento de normativas.
 - **Resultado:** Informe técnico con fallos detectados, nivel de riesgo y recomendaciones.
- ✅ **Ejemplo:** Un pentest descubre que un HMI accesible desde la red interna tiene una vulnerabilidad conocida sin parchear y se puede acceder como administrador.

Auditorías de ciberseguridad en entornos IT/OT

Auditoría vs evaluación de riesgos vs test de intrusión. Tabla comparativa

Característica	Auditoría	Evaluación de riesgos	Test de intrusión
Enfoque	Cumplimiento / control	Gestión del riesgo	Técnico / ofensivo
Naturaleza	Sistemático, documental	Estratégico	Práctico, simulación de ataque
Metodología	Normas y políticas	Análisis de amenazas y activos	Escaneos y explotación
Quién lo hace	Audidores (internos/externos)	Consultores de riesgos / CISO	Ethical hackers / red team
Resultado	Hallazgos y plan de acciones	Plan de tratamiento de riesgos	Vulnerabilidades y pruebas
Complementariedad	Sí	Sí	Sí

¿Cómo se complementan?

- La **evaluación de riesgos** identifica lo que más preocupa.
- La **auditoría** verifica que se estén tomando las medidas adecuadas.
- El **pentest** comprueba que esas medidas funcionan de verdad.

En entornos OT, los tres enfoques deben aplicarse con precaución y adaptaciones específicas para no afectar la operación.

Auditorías de ciberseguridad en entornos IT/OT

Planificación de una auditoría: qué se puede y qué no se puede hacer

La fase de planificación es crítica en cualquier auditoría, pero en entornos OT debe tratarse con especial **cautela** para evitar impactos operativos, errores de seguridad o interrupciones en la producción.

Lo que SÍ se puede (y debe) hacer

- **Definir un alcance claro**
 - Qué sistemas, plantas, redes, procesos o terceros se auditarán.
 - Distinguir entre IT y OT desde el inicio.
- **Involucrar a los responsables OT desde el principio**
 - Garantiza colaboración, evita resistencias y facilita el acceso a información relevante.
- **Planificar en función del calendario operativo**
 - Evitar épocas de alta producción, mantenimientos críticos o periodos sensibles.
- **Revisar documentación antes de entrar en planta**
 - Políticas, esquemas de red, incidentes anteriores, planes de contingencia.

Auditorías de ciberseguridad en entornos IT/OT

Planificación de una auditoría: qué se puede y qué no se puede hacer

✓ Lo que SÍ se puede (y debe) hacer

- **Establecer roles y responsabilidades**
 - Definir claramente quién será auditado, quién acompaña, y quién valida las actividades.
- **Comunicar claramente los objetivos y metodología**
 - Evita malentendidos, fricciones o sensaciones de control punitivo.
- **Garantizar la seguridad del personal auditor**
 - Formación en riesgos industriales, uso de EPIs si es necesario, zonas de acceso autorizadas.

✗ Lo que NO se debe hacer en una auditoría OT

- **No realizar pruebas intrusivas sin autorización expresa**
 - Escaneos de red o pruebas técnicas pueden afectar sistemas industriales delicados.
- **No interferir en procesos productivos en marcha**
 - Acceder a HMI, PLC o sistemas SCADA en funcionamiento puede generar paradas o errores.

Auditorías de ciberseguridad en entornos IT/OT

Planificación de una auditoría: qué se puede y qué no se puede hacer

✗ Lo que NO se debe hacer en una auditoría OT

- **No improvisar cambios de alcance sin validación previa**
 - Incluir nuevas áreas sin consultar puede romper acuerdos operativos.
- **No registrar información sensible sin consentimiento**
 - Fotografías, planos, contraseñas o configuraciones deben tratarse como datos críticos.
- **No emitir juicios personales o improvisar soluciones**
 - El auditor no es un consultor en ese momento, sino un evaluador imparcial.
- **No generar alarmas innecesarias**
 - La auditoría debe desarrollarse en un clima de confianza y profesionalidad.

Consejo práctico para auditores OT

“Planifica como si fueras parte del proceso, pero actúa como un observador crítico: sin interrumpir, sin alterar, sin invadir.”